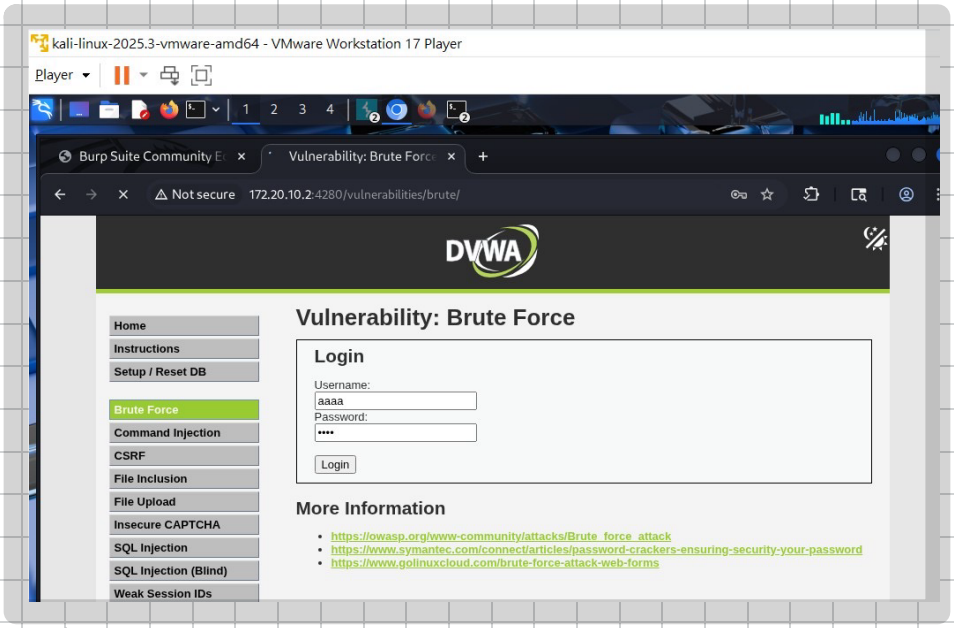
1008筆記：

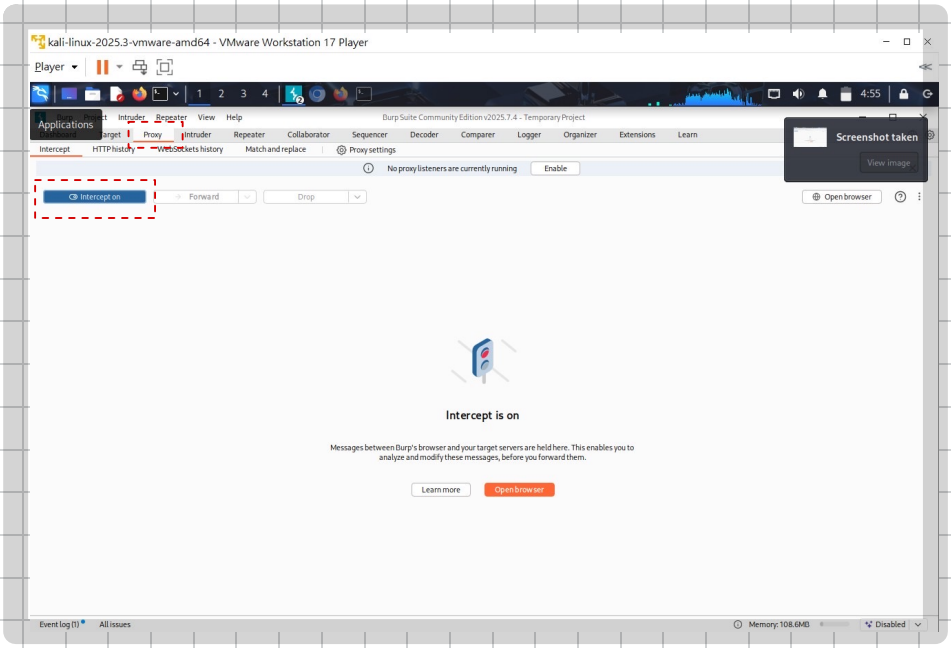
1. Burp Suite
- 是一套專業的應用程式安全測試工具，主要用於檢測和分析網頁應用程式的安全漏洞
- 功能
  - Proxy（攔截代理）
    - 攔截瀏覽器與伺服器間的HTTP/HTTPS流量
    - 即時查看和修改請求與回應內容，分析網頁應用程式的運用方式
  - Scanner（掃描器）
    - 自動掃描常見的網頁安全漏洞，包含SQL Injection、XSS、CSRF等漏洞檢測
    - 提供詳細的漏洞報告和修復建議
  - Intruder（入侵者）- 自動化攻擊工具
  - Repeater（重複器）
    - 手動修改HTTP請求，方便測試不同參數的回應結果
    - 適合進行細部的漏洞驗證
  - Decoder（解碼器）- 編碼和解碼各種格式
  - Comparer（比較器）- 比較兩個請求或回應的差異 ⇒ 分析微小變化的影響
- 使用場景
  - 搭配DVWA、WebGoat，了解HTTP協定運作原理
  - 學習常見網頁漏洞的攻擊手法
  - 專業滲透測試 - 網頁應用程式安全評估，漏洞控掘與驗證，生成專業的安全測試報告
  - 開發與除錯 - 分析網頁應用程式的API呼叫，除錯前後端溝通問題，測試應用程式的安全性

2. 操作 ⇒ 使用Burp Suite暴力破解DVWA Brute Force (Low)

① 在Kali虛擬機訪問Docker版DVWA（設定瀏覽器代理）



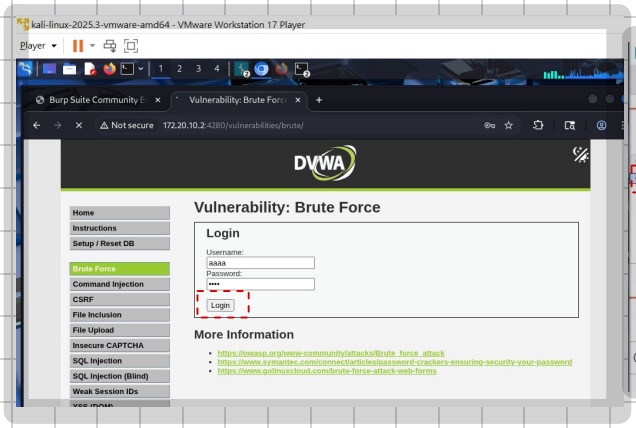
② 設定Burp Suite攔截

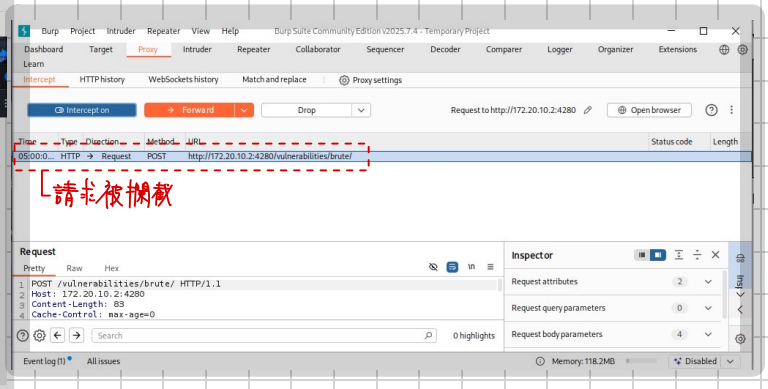


1008筆記：

2. 操作

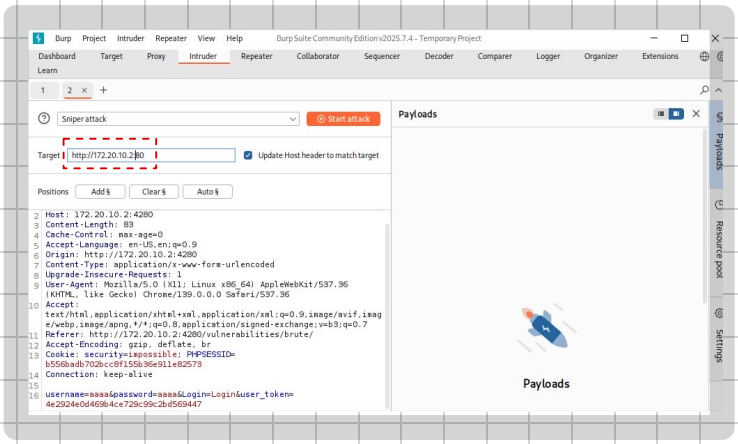
③進入DVWA Brute Force頁面，攔截登入請求





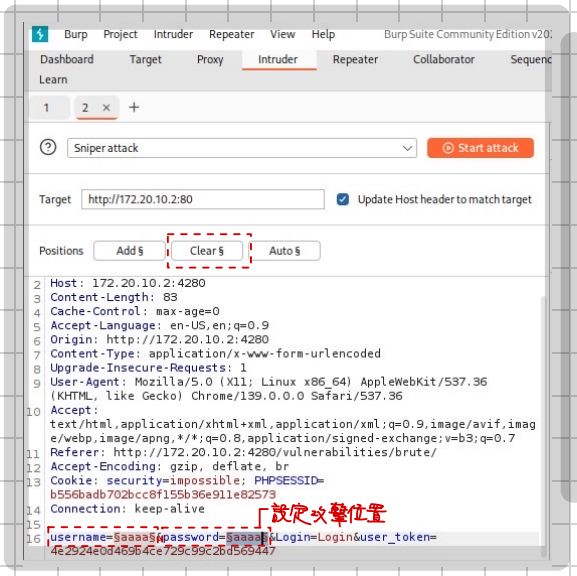
④將請求發送到Intruder，設定攻擊目標

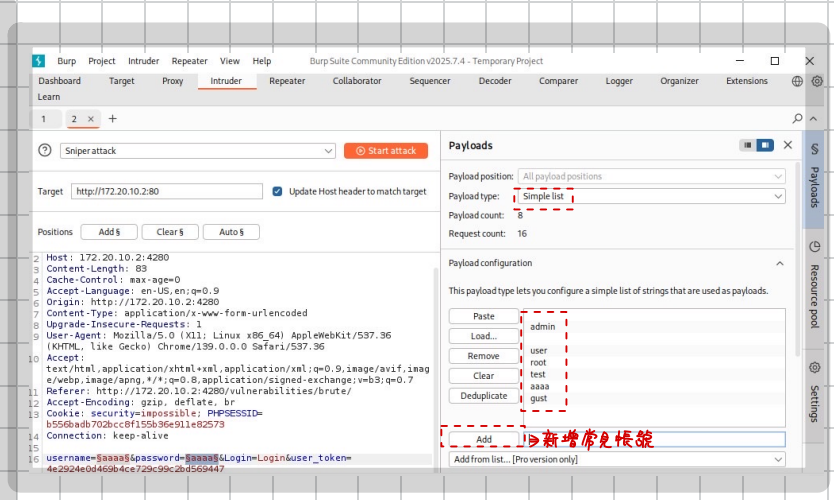
Ctrl + I



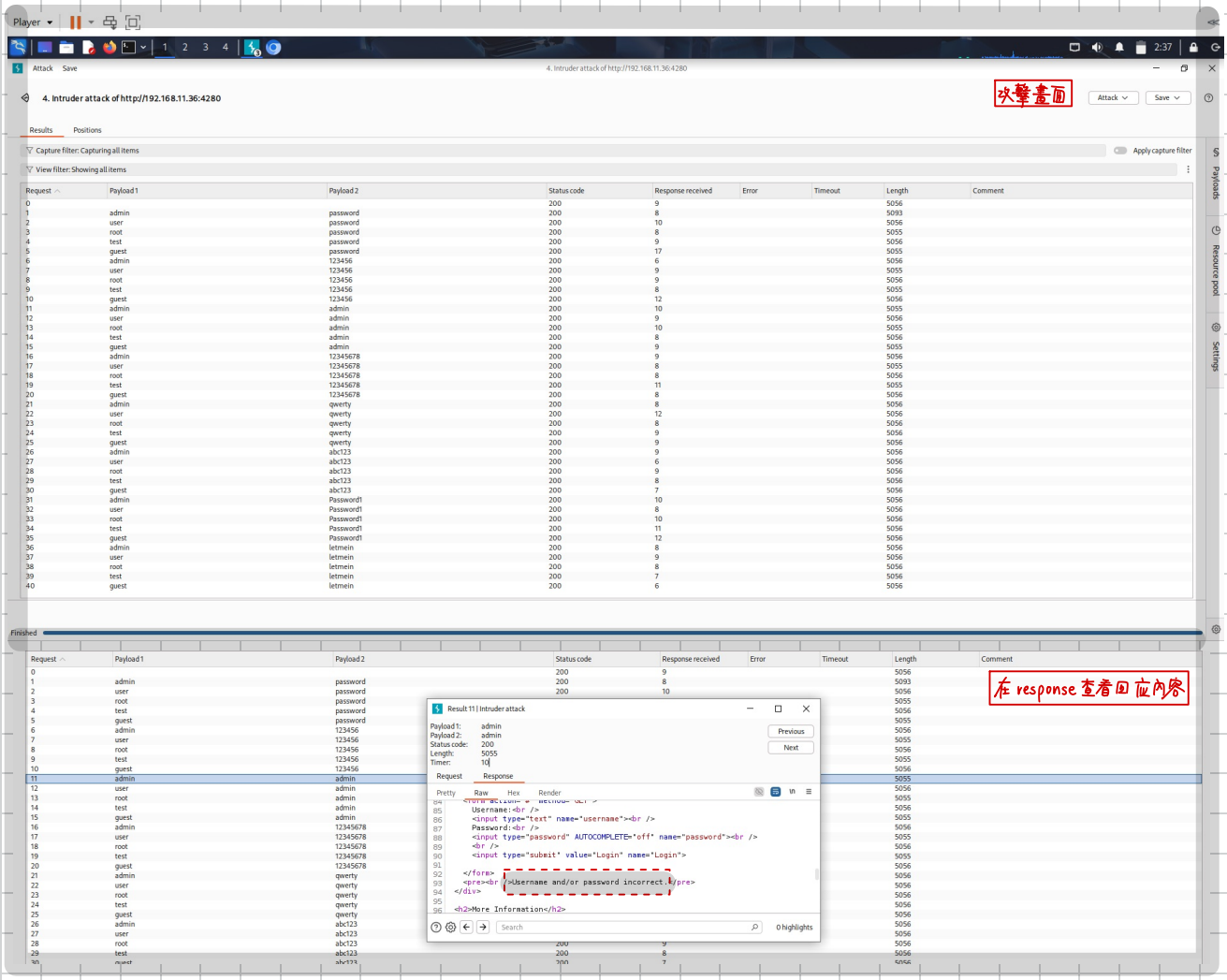
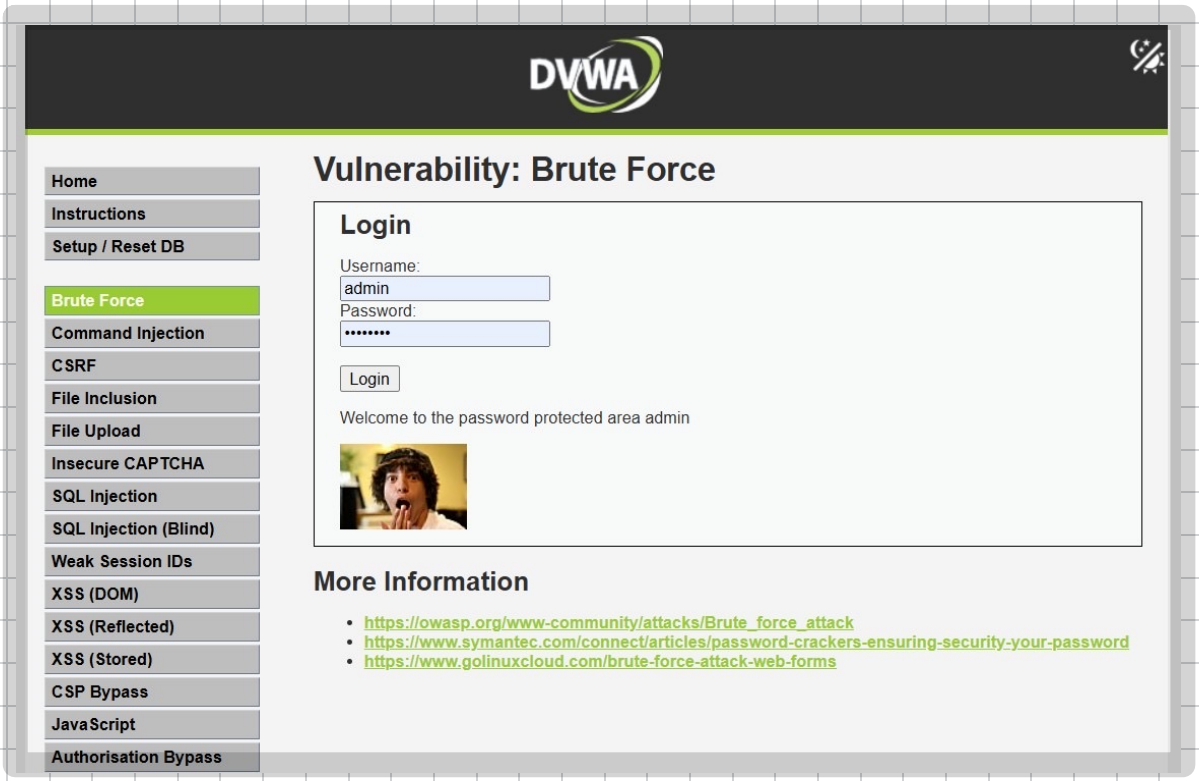
△ Host：DVWA的IP位置
Port：80 (HTTP) 或 443 (HTTPS)

⑤設定攻擊位置(Positions)，設定攻擊字典(Payloads)





⑥ 啟動攻擊 ⇒ ▶ Start attack，並驗證結果 攻擊畫面，在 response 查看回應內容



⑦ 暴力登入證明